

About Cascadian Bank

- **Type:** Small commercial bank headquartered in Port Harcourt.
- **Branches:** 3 branches (Port Harcourt Main, Trans-Amadi, Aba Road).
- **Staff Strength:** ~120 employees.
- **IT Infrastructure:**
 - Core Banking Application hosted on on-prem servers in HQ.
 - Customer portal and mobile app (internet-facing).
 - 150 workstations across branches.
 - 10 ATMs spread across the city.
 - Internal Wi-Fi for staff, public Wi-Fi for customers at branches.
- **Data Handled:**
 - Customer financial data (account balances, BVN, NIN, phone numbers).
 - Employee HR records.
 - Payment card details.
- **Critical Business Functions:**
 - Online banking services.
 - ATM cash withdrawals.
 - Loan application and processing.
 - Interbank transfers.

This context is the "business environment" step in NIST CSF. Always start with: *Who are we? What do we do? What's critical?*

Step 1: Risk Identification

We identify what could go wrong. Ask students: *What assets exist? What threats apply? What vulnerabilities exist? This mirrors ISO 27005's **Identify Assets** → **Identify Threats** → **Identify Vulnerabilities**.*

Assets

- Customer data (confidential).
- Core banking servers.
- ATMs.
- Staff laptops/desktops.
- Network infrastructure (routers, firewalls).

Threats

- Cybercriminals (phishing, malware, ransomware).
- Insider threat (disgruntled staff).
- Physical (theft of ATM, generator failure).
- Natural disasters (flooding in PH).

Vulnerabilities

- Outdated firewall rules.
- Weak password policies.
- Lack of security awareness training.
- Unencrypted backups stored onsite.

Step 2: Risk Assessment

👉 We analyse risks using two methods: qualitative (gut-feel ratings) and quantitative (financial estimates).

2A. Qualitative Risk Register (Likelihood × Impact)

Risk	Likelihood	Impact	Risk Level
Phishing attack on staff	High	Medium	High
Ransomware on core banking servers	Medium	High	High

Insider leaking customer data	Low	High	Medium
ATM skimming	Medium	Medium	Medium
Flood damaging HQ server room	Low	High	Medium
Public Wi-Fi exploited	High	Medium	High

Teaching Note:

- Likelihood = how often it could happen.
- Impact = how bad the damage is.
- This is simple and fast, but subjective — it relies on judgement.

2B Quantitative:

👉 Method:

- **Annual Rate of Occurrence (ARO):** How often risk is expected per year.
- **Single Loss Expectancy (SLE):** Estimated loss if it happens once (₦).
- **Annual Loss Expectancy (ALE):** Expected annual cost = **ARO × SLE**.

This gives management a **₦ number** to compare with cost of controls.

Example Register

Risk	Asset Affected	ARO (per year)	SLE (₦ Million)	ALE (₦ Million)	Priority
Phishing attack on staff	Staff email, customer data	3 (likely quarterly)	₦15m (fraud, recovery, fines)	₦45m	High
Ransomware on core banking servers	Core banking system	1 (annual likelihood)	₦120m (downtime, ransom, lost revenue)	₦120m	High

Insider leaking customer data	Customer database	0.5 (once in 2 yrs)	£ 200m (NDPA fines, reputational loss)	£100m	High
ATM skimming	ATMs, customer cards	2 (twice per year)	£ 20m (fraud reimbursements, ATM repair)	£40m	Medium
Flood damaging HQ server room	On-prem servers	0.2 (once in 5 yrs)	£ 250m (data center rebuild, downtime)	£50m	Medium
Public Wi-Fi exploited	Branch network, customer data	2 (twice per year)	£ 10m (incident response, reputation hit)	£20m	Medium

Step 3: Risk Evaluation (Prioritisation)

👉 We decide which risks deserve the most attention.

- **From Qualitative:** Top risks are → Phishing, Ransomware, Public Wi-Fi.
- **From Quantitative (ALE):** Top risks are → Ransomware (~~£~~120m), Insider Data Leak (~~£~~100m), Phishing (~~£~~45m).

Teaching Note:

- See how Insider Threat looks "Medium" in qualitative, but **jumps to High in quantitative** because of ~~£~~100m potential loss.
- This shows why many organisations do both — qualitative for speed, quantitative for business justification.

Step 4: Risk Treatment (Mitigation Strategies)

👉 Once prioritised, we decide how to handle each risk.

The **4 classic strategies**:

1. **Avoid** – Stop doing the risky thing.

2. **Reduce** – Add protections/controls.
3. **Share** – Transfer risk (insurance, outsourcing).
4. **Accept** – Live with it if cost of fixing > impact.

Example Treatment Plan (Cascadian Bank)

Risk	Treatment Strategy	Example Controls
Phishing	Reduce	Staff training, email filtering, MFA on logins
Ransomware	Reduce / Share	Encrypted offsite backups, EDR, anti-malware, cyber-insurance
Public Wi-Fi exploitation	Avoid / Reduce	Disable guest Wi-Fi; OR segregate via VLAN + captive portal
Insider threat	Reduce	Privileged access controls, continuous monitoring, HR vetting, whistleblower hotline
ATM skimming	Share / Reduce	Outsource ATM monitoring, anti-skimming devices
Flooding	Reduce / Share	Relocate servers to upper floor, offsite DR, insurance

Step 5: Risk Monitoring & Review

- Quarterly **penetration testing**.
- Monthly **patch management reports**.
- Continuous monitoring of **firewalls, logs, and SIEM**.
- Annual **risk reassessment**.